



Functional Testing of Security in Industrial Gateways under the New Machinery Regulation

Bachelor's Thesis T3_3300

Degree Programme Electrical Engineering

Field of Study Automation

Duale Hochschule Baden-Württemberg Ravensburg, Campus Friedrichshafen

by

Nathalie Nuber

Date of Submission:	July 31, 2026
Timeframe:	July 06, 2026 - July 31, 2026
Matriculation Number:	2257314
Course:	TEA 23
Dual Partner:	ifm ecomatic GmbH, Kressbronn a.B.
Supervisor:	M. Eng. Till Monzel
Reviewer:	M. Sc. Andreas Lau

Confidentiality Clause

The contents of this thesis may not be made available, either as a whole or in excerpts, to persons outside the examination and evaluation process, unless explicitly authorized by the Dual Partner. [End of restriction period: DD.MM.YYYY]

Kressbronn a.B., July 31, 2026

Nathalie Nuber

Nathalie Nuber



Declaration of Authorship

I hereby declare that I have authored this thesis independently, that I have not used other than the declared sources and resources, and that this thesis has not been submitted for any other examination with identical or comparable content, nor has it been published so far.

Kressbronn a.B., July 31, 2026

Nathalie Nuber

Nathalie Nuber

Abstract

English translation of the „Kurzfassung“.

Kurzfassung

Problemstellung

Ziel der Arbeit

Vorgehen und angewandte Methoden

Konkrete Ergebnisse der Arbeit, am besten mit quantitativen Angaben

200 bis 300 Wörter und beinhaltet die Fragestellung der Arbeit, die methodische Vorgehensweise sowie die Hauptergebnisse der Arbeit

Contents

1	Introduction	1
2	Fundamentals	2
2.1	Industrial Gateways in IT/OT Environments	2
2.1.1	Fundamentals of Industrial Gateways	2
2.1.2	IT/OT Interfaces	3
2.1.3	Attack Surface and Asset Identification	5
2.2	Regulatory and Standardization Framework	6
2.2.1	Regulation (EU) 2023/1230	6
2.2.2	prEN 50742	8
2.2.3	EN IEC 62443 Series	9
2.3	Cybersecurity Fundamentals	12
2.3.1	Security Goals	12
2.3.2	Threats, Vulnerabilities and Attack Vectors	13
2.4	Risk-Based Security Engineering	15
2.4.1	Threat Analysis and Risk Assessment (TARA)	15
2.4.2	STRIDE Methodology	16
2.4.3	Risk Evaluation	17
2.4.4	Risk Treatment Strategies	18
2.5	Security Testing Approaches	20
2.5.1	Testing Methodologies	20
2.5.2	Static and Dynamic Analysis	21
2.5.3	Vulnerability Assessment, Robustness, and Penetration Testing . .	22
3	Methodology	24
3.1	Regulatory Analysis under the EU Machinery Regulation	24
3.2	Normative Mapping and Technical Security Requirements	26
3.3	System Analysis	26
3.3.1	System Overview	27
3.3.2	System Architecture	27

3.3.3	Interfaces and Communication Channels	28
3.3.3.1	External Interfaces	28
3.3.3.2	Internal Interfaces	28
3.3.4	Communication Protocols	28
3.3.5	System Classification	29
3.3.6	Assets	29
3.3.6.1	Configuration Data	29
3.3.6.2	Firmware	30
3.3.6.3	Safety Configuration	30
3.3.6.4	Process Data	31
3.3.6.5	Diagnostic and Service Data	31
3.3.6.6	Device Identity Data	31
3.3.7	Attack Surface	32
3.4	Research of Test Methods	33
3.5	Analysis of the Gateway Security Context	34
3.6	Derivation of Security Requirements	34
3.7	Development of the Functional Security Testing Methodology	34
3.8	Security Test Categories	35
3.9	Test Case Structure	35
3.10	Roles and Responsibilities in Verification	36
3.11	Evaluation Criteria	36
4	Implementation, Results, and Evaluation	37
4.1	Test Environment	38
4.1.1	Test Object	38
4.1.2	Test Setup	38
4.1.3	Toolchain	38
4.2	Application of the Testing Methodology	38
4.2.1	Authentication Tests	38
4.2.2	Authorization Tests	38
4.2.3	Configuration Manipulation Tests	38
4.2.4	Firmware and Update Protection Tests	38
4.2.5	Logging and Traceability Tests	38
4.2.6	Communication Security Tests	38
4.3	Results	38
4.3.1	Test Results Overview	38
4.3.2	Evaluation of Mitigation Effectiveness	38
5	Summary and Outlook	39
5.1	Summary of Findings	39

5.2 Future Work	39
Bibliography	40
List of Figures	44
List of Tables	45
A Note on the Use of Artificial Intelligence	46

1 Introduction

security als konformitätsanforderungen

bedarfsecurity testing

Definition Cybersecurity

2 Fundamentals

2.1 Industrial Gateways in IT/OT Environments

2.1.1 Fundamentals of Industrial Gateways

Industrial gateways represent crucial architectural components that bridge the gap between distinct network environments by integrating both hardware and software functionalities. Their primary objective is to enable seamless communication between heterogeneous systems operating on different communication protocols. To achieve this, a gateway intercepts incoming data packets from a source system, translates or encapsulates the payload into a compatible format, and routes it to the target system. During this conversion process, protocol-specific overhead that is incompatible with the destination network is stripped away, while necessary parameters required by the target protocol are dynamically appended [1, pp. 277].

A gateway can operate across all layers of the Open Systems Interconnection (OSI) reference model [2]. In the context of this thesis, industrial gateways specifically facilitate the transition between Information Technology (IT) networks, typically dominant in layers 4 to 7, and Operational Technology (OT) networks, which operate heavily within layers 1 to 3 [3]. Consequently, managing this transition requires the gateway to reconcile various domain-specific constraints. These include differing physical layer standards, addressing schemes, transmission speeds, and data formats [2]. To ensure efficient translation, the protocol implementation and mapping generally occur at the lowest common layer shared by the interconnecting systems. Depending on the specific OSI layer at which the gateway operates, its internal processing mechanism and performance characteristics vary significantly [4].

2.1.2 IT/OT Interfaces

The ongoing digitization and networking within industrial value chains necessitate an increasing integration of two domains: Information Technology (IT) and Operational Technology (OT). While IT systems are primarily designed for the electronic storage, calculation, and transport of data, OT comprises a combination of hardware and software components explicitly utilized to monitor and control the performance of physical devices, machines, plants, and infrastructures. Operating predominantly within manufacturing and industrial environments, OT relies heavily on Industrial Control Systems, such as Supervisory Control and Data Acquisition (SCADA) systems [5, p. 1]. Traditionally, OT environments were realized as isolated networks relying on proprietary technologies. However, in the context of modern industrial paradigms, they are increasingly penetrated by networked technologies [5, p. 1].

Typical representatives of the IT domain include business-oriented software applications such as Enterprise Resource Planning (ERP) or Customer Relationship Management (CRM) systems. Conversely, the OT domain encompasses physical components on the shop floor, such as machines, scales, scanners, and sensors, along with the integrated control software that orchestrates them, such as Manufacturing Execution Systems (MES) [6, p. 404].

To systematically structure industrial environments, the architectural composition of OT can be categorized into four fundamental elements or functional levels [7]:

1. **Process Level:** This level consists of physical sensors and actuators that interact directly with the physical environment to perform actual mechanical work
2. **Control Level:** This layer comprises Programmable Logic Controllers (PLCs) and automated controllers that execute the underlying process logic and regulate physical operations in real-time
3. **Supervisory/Operation Level:** This level involves Human-Machine Interfaces (HMIs) and SCADA systems, which allow human operators to monitor system states visually, analyze anomalies, and intervene manually when necessary
4. **Operation IT / Data Layer:** Within this domain, raw OT data is aggregated, processed, and structured to make it valuable and actionable for higher-level applications

The technological convergence of IT and OT yields substantial operational and economic advantages. These advantages include enhanced transparency through the real-time acquisition of process data, the implementation of predictive maintenance strategies, the enablement of remote operation and maintenance, and comprehensive data-driven process optimization. Despite these benefits, IT/OT convergence introduces significant challenges, primarily because both domains operate under fundamentally conflicting requirements and distinct paradigms. These differences manifest across various dimensions, particularly regarding security priorities, protocols, and lifecycle management [7].

Table 2.1: Comparison of Core Characteristics and Requirements in IT and OT Environments [5, p. 1] [7]

Characteristic	Information Technology (IT)	Operational Technology (OT)
Primary Focus	Information processing and data flow	Monitoring and control of physical processes
Security Priorities	Confidentiality → Integrity → Availability	Availability → Integrity → Confidentiality
Core Security Objectives	Authentication, Non-repudiation	Real-time availability, Functional Safety
Protocol Examples	TCP/IP, HTTP(S), SQL	Modbus, Profinet
Update Cycles	Regular, frequent, and automated	Rare, conservative, and strictly validated

The attributes summarized in Table 2.1 highlight the fundamental misalignment between the two domains, which complicates seamless interface design. The most critical divergence lies within the prioritization of the CIA triad (Confidentiality, Integrity, and Availability). In IT paradigms, data confidentiality and robust authentication mechanisms occupy the highest priority to prevent unauthorized access to sensitive information. In contrast, OT environments prioritize maximum availability and deterministic real-time execution, as any latency or system interruption could lead to physical damage, production downtime, or severe safety hazards on the shop floor [5, p. 1] [7].

This divergence further dictates how software maintenance and network communication are handled. While IT infrastructures rely on frequent, rapid security patching and standard communication protocols (such as HTTP or SQL), OT infrastructures adopt a highly conservative update policy. Because OT systems require rigorous validation and recertification to guarantee absolute operational safety, patches are applied rarely and only during planned maintenance windows. Furthermore, the underlying network communica-

tion in OT utilizes deterministic, low-overhead protocols like Modbus or Profinet, which lack built-in security features such as encryption [7].

2.1.3 Attack Surface and Asset Identification



For a systematic assessment of Industrial Internet of Things components such as industrial gateways, a granular decomposition of the target architecture into hardware, software, and data assets throughout the entire product life cycle is required [8, pp. 1].

The hardware asset dimension comprises the physical enclosure. It may include tamper protection features, alongside the underlying printed circuit boards (PCB) and core microprocessors or microcontrollers. These processing units often embed specialized security mechanisms like Trusted Execution Environments, True Random Number Generators and cryptographic accelerators. Furthermore, hardware assets encompass volatile and non-volatile memory components such as SRAM and EEPROM structures, as well as removable storage like SD cards or USB sticks [8]. Dedicated secure cryptoprocessors, including Trusted Platform Modules and Secure Elements, are part of this domain, together with connectivity structures and various physical input and output elements [8, p. 3].

The software asset dimension is formed by the firmware providing low-level hardware access, the underlying operating system or real-time operating system, and software-based cryptographic libraries. It also contains integrated communication protocol stacks for local, internet, or automation environments, such as TCP/IP, PROFINET, or OPC UA, alongside local or remote smart services. At the top of this stack sits the specific application logic responsible for tasks like data pre-processing or controlling actuators [8, p. 4].

All these components interact with various data assets that must be identified, which include the executable device code itself, configuration data, specific application data from sensor readings, diagnostic log data, and essential authentication data [8, p. 4]. The overall attack surface of the device is defined by the sum of all entry points and attack vectors that target these individual components throughout the life cycle phases [8, p. 1].

On the hardware level, chip-level vectors include the malicious insertion of hardware Trojans during design or production, physical data manipulation, and fault injection e.g. via

voltage glitching [8, p. 8]. On the PCB level, vectors focus on design cloning. Device-level physical vectors involve general sabotage. The software and application attack surface is primarily driven by vulnerabilities within the embedded firmware components, such as flaws in network stacks that allow remote code execution or denial of service. Application-layer entries include input validation flaws like SQL injection, typical web application vulnerabilities, data injection via spoofed sensor inputs [8, p. 8]. The network interface exposes the device to classic automation protocol weaknesses that lack native security controls, enabling man-in-the-middle and replay attacks, distributed denial of service (DDoS) attempts, and port scans [8, p. 9].

2.2 Regulatory and Standardization Framework

2.2.1 Regulation (EU) 2023/1230

With the publication of Regulation (EU) 2023/1230 (MVO) on June 29, 2023, in the Official Journal of the European Union, the European legislature initiated a fundamental paradigm shift regarding the product safety of machinery [9, p. 32]. The new regulation replaces the former Machinery Directive 2006/42/EC and becomes mandatory following a transition period starting January 20, 2027 [10, p. 38].

The primary legal distinction lies in its regulatory form. While the previous directive was addressed strictly to EU member states, requiring transposition into national law, a regulation applies directly to all economic operators, including manufacturers, importers, and distributors [9, p. 32] [10, p. 15]. This creates a standardized, uniform legal framework across the Union without national leeway for interpretation [10, p. 38]. Furthermore, the regulation introduces legally binding definitions for fundamental concepts such as “substantial modification”, formally clarifying when an alteration to an existing machine turns an operator legally into a manufacturer subject to full conformity assessment procedures [10, p. 25].

A key driver for this overhaul was the identification of regulatory gaps within the previous directive regarding emerging digital technologies [10, p. 2]. Consequently, the Regulation incorporates mandatory requirements for cybersecurity and protection against malicious third parties into the framework of product safety for the first time [9, p. 33]. Under the Machinery Regulation, cybersecurity is explicitly treated as a prerequisite for machinery safety, demonstrating that the functional safety of modern machinery can no longer be

evaluated independently of its cybersecurity [11].

This digitalization shift is also reflected in structural updates across the regulation's annexes. Most notably, the explicit list of safety components in Annex II now formally includes standalone software that fulfills safety functions, establishing that non-tangible, digital components are subject to the same strict conformity requirements as physical safety hardware [10, p. 42 f]. Additionally, in line with modern operational practices, manufacturers are now explicitly permitted to provide instructions for use in a digital format, provided that specific access, availability, and preservation requirements are met [10, p. 19].

Specific requirements apply to the components under Regulation (EU) 2023/1230 [10, pp. 44]. Annex III, Section 1.1.9 formulates explicit provisions regarding protection against corruption:

- The connection of any external device to the machine must not lead to a hazardous situation through any function of the connected device or via a remote access device [10, p. 48]
- Hardware components transmitting signals or data relevant to safety-related software must be adequately protected against accidental or intentional corruption
- Software and data essential for compliance with safety requirements must be identified as such and adequately protected against corruption
- The machine must collect evidence of legitimate or illegitimate interventions in the relevant hardware, software, or its configuration [10, p. 49]

Complementarily, Annex III, Section 1.2.1 addresses the safety and reliability of control systems, requiring them to be designed to withstand reasonably foreseeable malicious attempts by third parties that could lead to hazardous situations. A failure or disruption in data transmission must not cause a hazardous situation [10, p. 49].

Furthermore, Article 10(2) [10, p. 18] and Annex IV Part A [10, p. 83 f] obligate manufacturers to maintain comprehensive technical documentation. This documentation must include the risk assessment, descriptions of implemented protective measures, as well as test reports and trial results proving actual conformity with safety requirements [10, p. 83]. Upon a reasoned request from competent national authorities, access to the source code or programming logic of safety-related software must also be provided [10, p.

84].

2.2.2 prEN 50742

While the new MVO defines the overarching regulatory safety objectives regarding cybersecurity, the harmonized standard draft prEN 50742 (published in Germany as DIN EN 50742 / VDE 0113-742) provides the specific technical guidance for engineering and implementation. The standard acts as a bridge between regulatory compliance and practical machine design, with its primary focus on fulfilling the essential health and safety requirements of the MVO, specifically Annex III, sections 1.1.9 (*Protection against corruption*) and 1.2.1 (*Safety and reliability of control systems*) [12, p. 70]. PrEN 50742 aims at protecting the machine's functional safety and control systems against digital and physical manipulation, ensuring that cyber threats cannot cause hazardous situations [12, p. 10]. A fundamental requirement of the standard is that any implemented cybersecurity measure must not under any circumstances compromise or degrade the functional safety of the machine, for instance by introducing impermissible latencies in safety-critical communication loops [12, p. 14].

To accommodate different organizational prerequisites and product architectures, the standard defines two distinct conformity paths for manufacturers [12, p. 15]. Approach A represents a standalone, machine-specific methodology directly linked to classical safety risk assessments according to EN ISO 12100 [12, p. 16]. Under Approach A, the required strength of countermeasures is determined by calculating the Safety Related Security Level (SRSL 0 to 3), which is derived from the attack potential combined with the severity of potential safety-related harm [12, pp. 19].

In contrast, Approach B is specifically designed for complex systems and components that are integrated into larger industrial communication networks. Instead of using the standalone SRSL framework, Approach B directly utilizes the established EN IEC 62443 series to define and verify technical security requirements [12, pp. 16, pp. 24]. Under this approach, the system as a whole must comply with EN IEC 62443-3-3, while individual machine components must meet the technical security requirements of EN IEC 62443-4-2 at a specified Capability Security Level (typically SL-C 1 or SL-C 2) [12, p. 24].

Despite their methodological differences, both paths share identical core objectives regarding the technical protection of interfaces and the verification of control system integrity [12, p. 15]. Depending on the determined security level (SRSL under Approach A or SL-C

under Approach B), both frameworks mandate equivalent critical mitigation measures. First, entities attempting to intervene must be authenticated, and logical access must be restricted through role-based authorization to prevent unauthorized physical or logical access [12, pp. 17, pp. 24]. Second, the integrity of safety-related application software (SRASW), embedded software (SRESW), and configuration data must be verified cryptographically (e.g., during secure boot or continuously during operation) [12, p. 17 f]. Furthermore, the integrity of exchanged information across network boundaries must be secured to prevent spoofing or tampering, which includes a strict validation of input data at external interfaces [12, p. 50]. Both approaches require the secure, tamper-resistant digital logging of all security-relevant interventions for a minimum of five years to ensure complete traceability [12, p. 19, S. 23]. Ultimately, prEN 50742 establishes that cybersecurity compliance cannot be achieved by design alone. All implemented technical countermeasures must be structurally verified. Under Approach B, this verification directly maps to the testing of security functions defined by the EN IEC 62443 sub-standards [12, p. 14].

2.2.3 EN IEC 62443 Series

Within the landscape of industrial cybersecurity, the international standard series IEC 62443 serves as the foundational framework for securing Industrial Automation and Control Systems [13, p. 13].

IEC 62443-3-3 delineates the system-level security requirements, thereby bridging the gap between high-level organizational policies and technical implementation [13, p. 15]. The primary objective of this standard is to safeguard the availability, integrity, and confidentiality of industrial environments through a structured, risk-based approach [13, p. 6].

To achieve this objective, the standard establishes seven core pillars, referred to as Foundational Requirements (FRs), which define the essential technical capabilities a system must possess:

- **FR 1: Identification and Authentication Control (IAC):** Ensures that all users, software processes, and devices are uniquely identified and authenticated before being granted access to the system [13, p. 29].
- **FR 2: Use Control (UC):** Monitors and restricts the privileges of authenticated

entities, ensuring they can only execute authorized actions in accordance with the principle of least privilege [13, p. 41].

- **FR 3: System Integrity (SI):** Protects the system, applications, and data from unauthorized or malicious modifications to guarantee the trustworthy operation of OT components [13, p. 50].
- **FR 4: Data Confidentiality (DC):** Safeguards sensitive information against unauthorized disclosure both at rest and in transit across communication channels [13, p. 57].
- **FR 5: Restricted Data Flow (RDF):** Segmentizes the industrial network into defined security zones and conduits, limiting data communication to the absolute necessary minimum to prevent lateral movement of threats [13, p. 61].
- **FR 6: Timely Response to Events (TRE):** Mandates continuous security monitoring, logging, and anomaly detection to facilitate rapid incident response and mitigation in the event of a breach [13, p. 65].
- **FR 7: Resource Availability (RA):** Ensures that the system remains operational and critical functions are maintained even when subjected to faults or Denial-of-Service attacks [13, p. 67].

The fulfillment of these foundational requirements is evaluated through a granular metric known as Security Levels (SL), which quantify the system's resilience against various adversary profiles [13, p. 16]. These levels scale from SL 1, representing protection against casual or coincidental violations, up to SL 4, which demands robust defenses against highly sophisticated, state-sponsored cyber threats utilizing significant resources [13, p. 26 f]. In the context of system validation, the standard further distinguishes between the targeted security posture (SL-Target), the innate technical capabilities of the integrated components (SL-Capability), and the actual security level realized during operation (SL-Achieved) [13, p. 26].

However, achieving and verifying system-level security requires not only technical features, but also a structured development process, based on the core principle that a secure product can only emerge from a secure development lifecycle [14, pection 4.2]. To address this, **IEC 62443-4-1** specifies the process-oriented requirements for a Secure Product Development Lifecycle (SDLC) [14, Chapter: Introduction]. The standard structures these lifecycle capabilities across eight core practice areas:

- **Practice 1: Security Management (SM):** Ensures that security activities are planned, documented, and governed throughout the entire product lifecycle [14, Chapter: Security Management].
- **Practice 2: Specification of Security Requirements (SR):** Defines functional and non-functional security requirements based on product intent and threat scenarios [14, Chapter: Specification of Security Requirements].
- **Practice 3: Secure by Design (SD):** Mandates secure architecture principles, defense-in-depth strategies, and threat modeling during system design [14, Chapter: Secure by Design].
- **Practice 4: Secure Implementation (SI):** Focuses on secure coding standards, code reviews, and avoiding known software vulnerabilities [14, Chapter: Secure Implementation].
- **Practice 5: Security Verification and Validation Testing (SV):** Requires systematic security testing, including dynamic analysis, interface testing, and fuzzing prior to release [14, Chapter: Security Verification and Validation Testing].
- **Practice 6: Management of Security-Related Issues (DM):** Establishes processes for tracking, analyzing, and resolving identified vulnerabilities or defects [14, Chapter: Management of Security-Related Issues].
- **Practice 7: Security Update Management (SUM):** Defines procedures for creating, testing, and distributing security patches to affected deployments [14, Chapter: Security Update Management].
- **Practice 8: Security Guidelines (SG):** Demands comprehensive documentation to enable end users to securely configure, deploy, and operate the component [14, Chapter: Security Guidelines].

To measure the organizational rigor and repeatability of these eight practice areas, IEC 62443-4-1 introduces a metric scheme known as Maturity Levels (ML), scaling from ML 1 to ML 4. While ML 1 describes informal and unmanaged practices, ML 2 signifies adherence to documented processes. Progression to ML 3 requires organization-wide implementation and verification, whereas ML 4 mandates continuous metrics-based optimization of all lifecycle practices [14, pecton 4.2].

Building upon these lifecycle practice, **IEC 62443-4-2** shifts the focus to the individual technical building blocks, specifying the technical security requirements for IACS components [15, p. 18]. The primary objective of this standard is to ensure that the components integrated into an industrial system inherently possess the necessary technical capabilities to support the overarching system-level Security Levels (SL). To achieve this, the standard maps the seven Foundational Requirements (FRs) defined in the system-level framework directly onto four distinct component types: software applications, embedded devices, host devices, and network components [15, p. 17].

Analogous to the system-level standard, the concrete technical specifications within IEC 62443-4-2 are structured as Component Security Requirements (CRs) and further refined by Requirement Enhancements (REs)[15, pp. 32]. These CRs and REs are directly derived from the seven FRs, acting as the granular technical criteria that a component must satisfy to achieve a specific Component Security Level Capability (SL-C) [15, pp. 31].

For instance, while a system requires restricted data flow under FR 5, IEC 62443-4-2 translates this into explicit component capabilities, such as the network component's ability to enforce logical isolation, manage access control lists, and securely route or filter traffic at the physical IT/OT interface [15, pp. 61].

2.3 Cybersecurity Fundamentals

2.3.1 Security Goals

Within the domain of digital information security, the systemic alignment of cybersecurity strategies is traditionally anchored within a foundational guiding framework known as the *CIA (Confidentiality-Integrity-Availability) triad* [16] [17, p. 1]. This paradigm conceptualizes the three primary objectives required to establish a security posture and protect information assets against digital threats [18, p. 5]. To evaluate and mitigate risks effectively, these three distinct dimensions form the theoretical baseline [17, p. 24]:

- **Confidentiality:** Focuses on ensuring that sensitive data and information are strictly protected from unauthorized access or disclosure to unintended individuals, entities, and processes [18, p. 4] [17, p. 3]. In the specific context of IACS, the maintenance of authorized restrictions on access becomes paramount to secure

proprietary information, data configurations, and core operational parameters from illicit exposure [13, p. 23].

- **Integrity:** Revolves around the complete assurance that information and system components remain accurate, reliable, and trustworthy throughout their entire life-cycle [18, p. 4] [17, p. 3]. This objective actively safeguards digital assets against accidental or unauthorized modifications, deletions, and fabrications, which prevents erroneous decision-making or potential operational harm caused by altered data [18, pp. 4].
- **Availability:** Guarantees that essential services, computing systems, and communication interfaces remain continuously accessible and operational for authorized users precisely when needed [18, pp. 4] [17, p. 3]. This dimension dictates the overall resilience of the architecture against malicious disruptions, ensuring that operations can be sustained or recovered quickly to maintain customer trust and minimize financial losses [18, p. 5].

In practical deployment, these three primary security goals do not operate in isolation but exhibit a complex dynamic where they concurrently work together  against each other, frequently necessitating deliberate design trade-offs to balance conflicting requirements. While this triad establishes an essential baseline for data protection, modern distributed network environments demand explicit extensions to the classical CIA framework to address sophisticated threat vectors comprehensively. Possible additions include the goals of authenticity, and usefulness. Authenticity focuses on verifying that the transmitted information or system state genuinely is what it claims to be and incontrovertibly originates from the expected, legitimate source. Utility demands that data remains in a structurally usable, meaningful, and actionable form rather than merely being technically accessible to the organization [16] [19, pp. 102].

2.3.2 Threats, Vulnerabilities and Attack Vectors

A **threat** constitutes a circumstance, an event, or a various sequence of events capable of adversely affecting or compromising operations, including an organization's mission, functions, reputation, or standing. Furthermore, threats can directly target physical facilities, assets, automation and control systems, or individuals. These adverse impacts are typically realized through specific malicious actions, such as unauthorized access to data, its destruction, unauthorized disclosure, data alteration, or denial-of-service attacks

[13, p. 23].

A **vulnerability** represents a flaw in a system's design, implementation, or operation that can be exploited to corrupt system integrity [12, p. 12]. Although vulnerabilities are categorized into distinct types, the exact probability of their malicious exploitation cannot be predicted. Crucially, vulnerabilities do not create new physical hazards on their own. However, their exploitation can compromise integrated protective measures, which necessitates a formal threat assessment [12, p. 9]. To manage these latent risks, designers must adhere to a strict three-step mitigation hierarchy. First, present vulnerabilities that could cause hazardous situations must be eliminated entirely. Second, if complete elimination is technically unfeasible, the designer must actively mitigate the identified weakness. Finally, for any residual vulnerabilities, the information for use must provide the operator with detailed instructions for compensating countermeasures [12, p. 14].

An **attack vector** defines the specific method or means by which hackers gain unauthorized access to target systems in order to carry out a cyberattack. To ensure that no potential attack vectors are overlooked during the architectural analysis, a thorough, granular itemization of all hardware components, software components, and data types is required [8, p. 2] [8, p. 11]. Together, an organization's active attack vectors and its technical vulnerabilities constitute its total attack surface. In modern connected environments, this attack surface has continuously increased, exposing industrial assets to various common types of attack vectors utilized by adversaries, including:

- Third-party and supply chain compromises
- Denial-of-Service (DoS) attacks
- Compromised credentials
- Insider threats
- Exploitation of unpatched software or hardware vulnerabilities
- Injection and execution of malware
- Physical attacks on the infrastructure

Ultimately, the successful exploitation of these vectors allows attack actors to disable or destroy critical operational assets, which subsequently leads to significant business and

economic disruptions [20].

2.4 Risk-Based Security Engineering

2.4.1 Threat Analysis and Risk Assessment (TARA)

Threat Analysis and Risk Assessment (TARA) serves as a systematic methodology in cybersecurity to identify potential threats, assess associated risks, and formulate countermeasures to mitigate them to an acceptable level [19, p. 37]. Rather than relying on guesswork, TARA functions as a central tool to methodically derive concrete Cybersecurity Goals [21]. As part of overall risk management, it plays a critical role in ensuring regulatory compliance and producing secure products. The process is universally applicable across domains. However, conducting a TARA requires deep knowledge of the target system combined with specialized cybersecurity expertise. While it uncovers vulnerabilities and weaknesses, a TARA cannot provide definitive proof of security or guarantee an absolute defense [19, p. 38].

Throughout the system lifecycle, TARA is implemented iteratively across four distinct phases [19, p. 40]. An initial TARA occurs during early requirements engineering to evaluate baseline risks and define high-level security goals for the architecture. Before implementation begins, a detailed development TARA identifies component-level risks or adapts existing assessments for reused parts. During production, TARA evaluates manufacturing environments to prevent introducing vulnerabilities into the physical product. Finally, post-release TARAs are triggered by software updates or newly discovered vulnerabilities to continuously keep the risk profile up to date [19, p. 40].

The general workflow executes a sequential multi-step process from Item Definition and Asset Identification to Threat Analysis, Impact Rating, Feasibility Assessment, Risk Determination, and Risk Treatment. Within this context, a threat describes a potential event violating a cybersecurity property (Confidentiality, Integrity, or Availability), whereas a vulnerability represents a concrete weakness in design or implementation enabling that threat [21].

In practice, these workflow steps structure the primary operational domains of the assessment [19, p. 47, 49]. First, Asset Identification determines system assets, their required CIA properties, and prospective damage scenarios to establish an initial impact rating [19,

p. 46, 49][21]. Next, Threat Scenario Analysis defines potential attack vectors alongside specific attack paths, which detail the sequential steps an adversary must execute [19, p. 46][21]. Because no single threat source is comprehensive, team brainstorming supported by catalogs and the STRIDE methodology offers an efficient approach to threat identification [19, p. 135, 137]. Subsequently, Risk Evaluation combines the calculated impact ratings with attack feasibility metrics to derive overall risk levels [19, p. 47, 49][21]. Finally, the Risk Treatment Decision determines final Cybersecurity Controls, Goals, and Claims to effectively reduce identified risks [19, p. 37, 49][21].

2.4.2 STRIDE Methodology

The STRIDE methodology is a widely used threat modeling approach developed by Microsoft to address the fundamental question of what can go wrong in a system [22] [19, p. 143]. Rather than acting merely as a static threat categorization, STRIDE serves as a useful method for identifying specific threats based on potential attacker goals [19], [23].

The acronym STRIDE represents six distinct threat categories:

- **Spoofing:** The attacker pretends to be someone or something else. This involves illegally accessing and using another entity's authentication credentials, such as a username and password, or spoofing components and signals within embedded networks
- **Tampering:** Refers to the unauthorized, malicious modification of data or system functionalities. Examples include altering persistent data in a database, modifying firmware, or tampering with data in transit over an open network
- **Repudiation:** Occurs when an attacker performs a prohibited action in a system that lacks the ability to trace or audit operations, allowing the actor to deny performing the action without the system having proof otherwise
- **Information Disclosure:** Involves the exposure of data to unauthorized individuals. This includes data breaches, unauthorized file access, or reading data in transit across network connections
- **Denial of Service:** Threat actions aiming to disrupt system operation or deny access to legitimate users. Examples include making web servers temporarily unusable

or flooding bus systems with traffic to block valid messages

- **Elevation of Privilege:** An unprivileged attacker exploits vulnerabilities to gain higher access privileges than authorized. This allows the attacker to penetrate system defenses, access critical subsystems, and potentially compromise the entire system [22] [19, p. 144]

To systematically analyze these threats, Table 2.2 illustrates how each STRIDE category maps directly to the specific cybersecurity property it violates.

Table 2.2: Mapping of STRIDE Threat Categories to Violated Cybersecurity Properties [19, p. 144] [23]

Threat Category	Cybersecurity Property Violated
Spoofing	Authenticity
Tampering	Integrity
Repudiation	Non-repudiation
Information Disclosure	Confidentiality
Denial of Service	Availability
Elevation of Privilege	Authorization

As shown in Table 2.2, the STRIDE threat categories represent the direct opposite of fundamental security objectives. By systematically evaluating system components against these paired relationships, threat lists can be derived to identify potential attacker goals and define required security controls [19, p. 144] [23].

2.4.3 Risk Evaluation

Risk evaluation serves as the central mechanism to determine and quantify the overall risk level associated with identified threat scenarios. Fundamentally, risk is defined as a combination of the potential impact resulting from an attack and its corresponding likelihood or feasibility [19, p. 196]. In literature, this relationship is frequently expressed through formal mathematical models. For instance, the risk level (R) can be determined by multiplying the likelihood (L) by the severity (S) of the impact [6, p. 648]:

$$R = L \cdot S \quad (2.1)$$

To systematically assess the impact parameter (I), criteria are established based on operational and safety domains. In safety-critical industrial environments, the impact rating

evaluates potential physical harm to humans across four distinct levels [19, p. 106]:

- **Severe (S3):** Fatal injuries or severe, life-threatening injuries where survival is uncertain
- **Major (S2):** Severe and life-threatening injuries where survival is probable
- **Moderate (S1):** Light to moderate physical injuries
- **Negligible (S0):** No physical injuries occur

Complementarily, the feasibility evaluation (F) determines the probability of occurrence by analyzing the technical effort and capabilities required for an adversary to execute specific attack paths [19, p. 135]. Attack feasibility is categorized into four distinct ratings [19, p. 151]:

- **High:** The attack path can be accomplished utilizing low effort
- **Medium:** The attack path can be accomplished utilizing medium effort
- **Low:** The attack path can be accomplished utilizing high effort
- **Very Low:** The attack path can be accomplished utilizing very high effort

For the final evaluation, assets, threat scenarios, attack paths, and resulting damage scenarios are combined into a structured matrix [19, p. 180]. By mapping the discrete impact ratings against the corresponding attack feasibility levels in a standardized risk matrix, the final numerical risk value is calculated. For instance, a damage scenario categorized with a *moderate* impact rating and a *high* attack feasibility yields a resulting risk value of three [19, p. 180]. Depending on specific institutional requirements and risk tolerance thresholds, individual organizations can make tailored adjustments to the underlying risk matrix structures [19, p. 182].

2.4.4 Risk Treatment Strategies

Following the evaluation of identified risks, appropriate risk treatment strategies must be defined. Generally, four primary strategies are available to address identified risks: risk

reduction, risk avoidance, risk sharing, and risk acceptance [19, pp. 200].

Risk Reduction: Risk reduction aims to decrease either the impact or the likelihood of a threat scenario. This is achieved by implementing technical countermeasures, also known as cybersecurity controls, which are typically derived from standardized or corporate catalogs [19, p. 200]. Table 2.3 summarizes standard technical mitigation techniques mapped to the corresponding STRIDE threat categories [23].

Table 2.3: Technical Mitigation Techniques Mapped to STRIDE Threat Categories [23]

Threat Type	Mitigation Techniques
Spoofing Identity	Appropriate authentication, protection of secret data, avoiding secret storage
Tampering	Appropriate authorization, cryptographic hashes, MACs, digital signatures, tamper-resistant protocols
Repudiation	Digital signatures, timestamps, audit trails
Information Disclosure	Authorization, privacy-enhanced protocols, encryption, protection or non-storage of secrets
Denial of Service	Appropriate authentication and authorization, traffic filtering, throttling, Quality of Service
Elevation of Privilege	Execution under the principle of least privilege

Risk Avoidance: Risk avoidance involves modifying the fundamental design of the system component to eliminate the source of the risk entirely [19, p. 200].

Risk Sharing: Risk sharing distributes the risk among other stakeholders via contractual agreements or transfers it through insurance policies. In this case, a formal rationale in the form of a cybersecurity claim must be documented [19, p. 201].

Risk Acceptance: If the resulting risk level, impact, or attack feasibility is sufficiently low, accepting the risk represents a valid decision. Risk acceptance does not mean ignoring the threat. It strictly requires a documented rationale and cybersecurity claim to justify the acceptance [19, p. 201].

Once potential threats and corresponding countermeasures are established, a system threat profile can be derived into three distinct levels of mitigation [23]:

- **Non-mitigated threats:** Threats without countermeasures that expose fully exploitable vulnerabilities.
- **Partially mitigated threats:** Threats partially addressed by controls, resulting

in limited exploitability and impact.

- **Fully mitigated threats:** Threats with adequate countermeasures in place that leave no exposed vulnerabilities.

Even after implementing technical controls, a residual risk, may remain high. Residual risk represents the actual risk level present when an adversary attempts an attack path while active technical controls are in place [19, pp. 200].

2.5 Security Testing Approaches

Functional testing verifies whether a System Under Test (SUT) fulfills its specified primary functions. In contrast, non-functional testing evaluates aspects such as performance, usability, and security. Ensuring software security requires dedicated effort during development to identify vulnerabilities and implement effective protective measures. Security testing serves as a primary method to uncover these weaknesses [24, p. 291].

Software security testing activities are divided into functional security testing and security vulnerability testing. Functional security testing verifies the correct operation of planned security mechanisms, such as access control or authentication systems [25, p. 82] [26, p. 8]. Vulnerability testing aims to discover unaddressed design flaws and implementation bugs [26, p. 8]. A comprehensive testing strategy must combine both approaches to validate security features while simulating realistic attack scenarios [25, p. 81 f].

2.5.1 Testing Methodologies

Security testing approaches are categorized by the level of internal system knowledge available to the tester [24, p. 296]:

- **Black-Box Testing:** The tester has no knowledge of the internal system structure [24, p. 296]. Testing evaluates external software interfaces by executing the program with various inputs [25, p. 82]. Subcategories include fuzzy testing, which injects randomly generated data to infect or damage a system, and property-based testing, a model-based approach converting security properties into specifications via program slicing [24, p. 296].

- **White-Box Testing:** The evaluator has full access to the source code, logical paths, and architectural design. It enables manual code reviews, model-based techniques that check system models against security requirements, and fault injection to test interaction limits under malicious commands [24, p. 296].
- **Grey-Box Testing:** Tests are conducted with limited knowledge of the internal architecture by combining white-box and black-box techniques across multiple system layers [24, p. 296].

Techniques that cannot be strictly categorized into these paradigms include ethical hacking, penetration testing, and security regression testing. Penetration testing mimics actual attacker behavior to exploit system vulnerabilities. Ethical hacking expands this focus to evaluate weak points across the entire environment, including human operators and clients. Security regression testing specifically verifies that system upgrades or changes do not introduce new vulnerabilities [24, p. 296].

2.5.2 Static and Dynamic Analysis

Security analysis techniques are structured into static and dynamic execution paradigms. Static analysis inspects source code or control and data flow graphs using checklists without exercising the system with real runtime data [26, p. 35]. It detects errors early in development, but may miss runtime flaws [27, p. 1]. Conversely, dynamic analysis evaluates system behavior during runtime under different configurations and input data, comparing actual outputs against formal specifications [26, p. 35]. Dynamic testing provides real-world validation, it can disrupt system operations [27, p. 1].

Static Analysis Mechanisms: Static Application Security Testing (SAST) examines source code or binaries without execution [28]. As shown in Table 2.4, static detection primarily relies on code similarity-based and code pattern-based approaches [27, pp. 3]:

- **Code Similarity-Based Detection:** Identifies potential vulnerabilities by searching for known vulnerable code clones via string comparison, syntax analysis, or machine learning [27, p. 3]. Grammar-based techniques analyze grammatical code structures, whereas semantic-based techniques evaluate control and data flows to determine code meaning [27, pp. 4]. This approach requires less training data but cannot detect novel vulnerabilities [27, p. 8].

- **Code Pattern-Based Detection:** Utilizes machine learning and deep learning during a training and detection phase to recognize specific vulnerable code patterns [27, p. 5]. While dependent on data, it can discover new vulnerabilities [27, p. 8].

Combining both static approaches increases overall vulnerability detection effectiveness [27, p. 8].

Table 2.4: Comparison of Static Analysis Detection Approaches [27, p. 3, 8]

Property	Code Similarity-Based	Code Pattern-Based
Operating Principle	Searches for similar code clones	Identifies specific code patterns
Techniques Used	String comparison, syntax and semantic analysis	Machine learning, deep learning
Advantages	Less dependent on training data	Capable of detecting new vulnerabilities
Disadvantages	Unable to detect new vulnerabilities	Highly dependent on training data

Dynamic Analysis Mechanisms: Dynamic Application Security Testing (DAST) evaluates running applications under real-world attack conditions [28]. Advanced dynamic penetration testing methodologies employ planning-based or reinforcement learning-based approaches to discover execution paths [27, p. 6]. Furthermore, Interactive Application Security Testing (IAST) combines static and dynamic feedback during runtime, while Software Composition Analysis (SCA) audits third-party dependencies for vulnerabilities and license compliance [28].

2.5.3 Vulnerability Assessment, Robustness, and Penetration Testing

A comprehensive testing framework requires evaluating feature functionality, performance, and robustness [26, p. 48]:

- **Vulnerability Scanning:** Automated tools scan hosts, open ports, and operating systems to match system configurations against databases of known vulnerabilities [29, p. 27].
- **Robustness Testing and Fuzzing:** Robustness measures a system's ability to operate correctly under exceptional inputs or environmental stress [26, p. 39]. Fuzzing

is an automated robustness testing technique that repeatedly injects invalid, random, or unexpected inputs into target interfaces to provoke data handling errors or crashes. Fuzzing varies by input generation: “dumb” fuzzing performs random mutations without input format knowledge, while “smart” fuzzing uses input models. Based on system access, white-box fuzzing utilizes program analysis, grey-box fuzzing uses lightweight instrumentation, and black-box fuzzing operates without internal knowledge [27, p. 8] [26, p. 29].

- **Penetration Testing:** Evaluators mimic real-world cyberattacks to identify exploitable vulnerability combinations [24, p. 296]. According to NIST SP 800-115, penetration testing follows four stages: *Planning*, *Discovery*, *Attack*, and *Reporting* [29, p. 37].
- **Fault Injection and Mutation Testing:** Fault injection evaluates interaction points by forcing the system to process malicious commands [24, p. 296]. Mutation testing evaluates test suite effectiveness by injecting single syntactic changes, such as variable renaming or operator replacements, to create faulty software versions. It relies on three core assumptions: competent programmers make small errors, selected mutation operators represent typical human errors, and a coupling effect allows simple mutations to uncover subtle bugs [26, p. 50].

3 Methodology

3.1 Regulatory Analysis under the EU Machinery Regulation

Table 3.1: Regulatory Cybersecurity Requirements for Industrial Gateways derived from Regulation (EU) 2023/1230

REQ ID	MVO Reference	Regulatory Core Mandate
REQ-REG-01	Annex III, Sec. 1.1.9	External device connections and remote access facilities must not cause hazardous situations.
REQ-REG-02	Annex III, Sec. 1.1.9	Hardware components transmitting safety-critical signals/data must be protected against intentional or accidental corruption.
REQ-REG-03	Annex III, Sec. 1.1.9	Mandatory collection of evidence/logs regarding legitimate or illegitimate access/interventions in safety-relevant hardware.
REQ-REG-04	Annex III, Sec. 1.1.9	Explicit identification and corruption protection of software and data critical for health and safety compliance.
REQ-REG-05	Annex III, Sec. 1.1.9	Mandatory identification and continuous, accessible display of installed safety-critical software versions.
REQ-REG-06	Annex III, Sec. 1.1.9	Evidence logging of any legitimate or illegitimate modifications to installed software or machine configuration.

Continued on next page –

- Continued from previous page -

REQ ID	MVO Reference	Regulatory Core Mandate
REQ-REG-07	Annex III, Sec. 1.2.1(a)	Control system resilience against operational stresses, external influences, and foreseeable malicious third-party attacks.
REQ-REG-08	Annex III, Sec. 1.2.1(b, c, e)	Fault tolerance ensuring hardware/software defects, logic errors, or foreseeable operator errors do not lead to hazardous situations.
REQ-REG-09	Annex III, Sec. 1.2.1(d)	Strict prevention of unauthorized setting or rule modifications (including during learning phases) that could cause hazards.
REQ-REG-10	Annex III, Sec. 1.2.1(f)	Mandatory retention of audit trails for software interventions and uploaded safety software versions for 5 years.
REQ-REG-11	Article 10(2) & Annex IV Part A	Technical documentation must include empirical test reports proving compliance with cybersecurity requirements
REQ-REG-12	Annex III, Sec. 1.2.6	Interruption, fluctuation, or re-establishment of communication network connections must not lead to hazardous situations.
REQ-REG-13	Annex III, Sec. 3.3.3 & 5.2.4	Interruption or loss of wireless/remote communication signals must automatically trigger a safe state (e.g., safe stop).
REQ-REG-14	Annex IV Part A, Sec. 1(v)	Technical documentation must include safety-related software architecture, programming logic/source code, and validation results.
REQ-REG-15	Art. 3 & Annex II	Standalone safety software carrying out safety functions must undergo dedicated conformity assessment as a safety component.

3.2 Normative Mapping and Technical Security Requirements

FR1, FR2, FR5: Zugriffssteuerung & Netz FR3, FR4: Integrität & Datenschutz FR6, FR7: Resilienz & Verfügbarkeit

FR1: Wer darf auf das System zugreifen? FR2: Was darf ein Benutzer tun? FR3: Kann das System manipuliert werden? FR4: Können Daten mitgelesen werden? FR5: Können Kommunikationswege kontrolliert werden? FR6: Werden Sicherheitsereignisse erkannt und protokolliert? FR7: Bleibt das System auch unter Angriffen funktionsfähig?

REQ-REG 1: FR1 (FR2, FR4, FR5, FR7) REQ-REG 2: FR3 REQ-REG 3: FR6 REQ-REG 4: FR3 REQ-REG 5: (FR3) REQ-REG 6: (FR2, FR3) FR6 REQ-REG 7: (FR3) FR5, FR7 REQ-REG 8: (FR3), FR7 REQ-REG 9: FR1, FR2, (FR3) REQ-REG 10: FR6 REQ-REG 11: IEC 62443-4-1

REQ-REG 1: 1.1, 1.2, 2.1, 5.1, 5.2 REQ-REG 2: 3.1, 3.8 REQ-REG 3: 6.1, 6.2 REQ-REG 4: 3.4 REQ-REG 5: 3.4 (1.2) REQ-REG 6: 6.1, 6.2 REQ-REG 7: 7.1, 7.2, 7.3 REQ-REG 8: 3.3, 7.1, 7.2 REQ-REG 9: 1.1, 2.1, (3.3) 3.4 REQ-REG 10: 6.1, 6.2 REQ-REG 11: SVV1, SVV2, SVV3, SVV4, DM1, DM2

SR: Generelle Anforderungen an den Betrieb und das Gesamtsystem CR: Produktspezifische Anforderungen unterteilt nach Komponententyp

3.3 System Analysis

The purpose of the system analysis is to establish a detailed understanding of the System Under Consideration (SUC). This includes the system architecture, available interfaces, communication mechanisms, critical assets, trust boundaries, and the overall attack surface.

3.3.1 System Overview

The Safe Remote I/O (SRIO) is a fieldbus-based safety device used within industrial automation systems. It acquires binary 24 V input signals from safety sensors and transmits them to a higher-level safety controller (F-Host) via PROFIsafe communication. In addition, the device receives output commands from the F-Host and controls connected actuators through safety-related digital outputs. The device supports both safety-related and non-safety-related communication functions. The system consists of the following main components:

- **Communication Module (COM):** Provides Ethernet-based communication, PROFINET connectivity, IoTCore functionality, web services, firmware update handling, and data storage access
- **System Communication (SysCom):** Internal SPI-based communication channel between COM and SCPU
- **Safety CPU Module (SCPU):** Implements the safety functions using a 1oo2 architecture consisting of two independent safety controllers, cross-communication mechanisms, and a watchdog
- **Power Supply Module (PS):** Supplies all internal system components.
- **Digital Input Module (DI):** Provides six safe digital input channels.
- **Digital Output Module (DO):** Provides two safe digital output channels.

3.3.2 System Architecture

The SRIO architecture separates safety-related and non-safety-related functionality. The COM module acts as the communication gateway. It handles PROFINET communication, the IoTCore web interface, firmware update services, and network management functions. The COM module is based on a dedicated communication processor and a fieldbus controller. The SCPU module implements the safety application. Two independent safety controllers execute the safety logic and exchange diagnostic information through internal communication channels. A watchdog mechanism supervises correct system operation. Communication between COM and SCPU is performed via the SysCom

interface. Safety-relevant communication is transmitted using the black-channel principle, where PROFIsafe messages are transported over standard PROFINET communication.

3.3.3 Interfaces and Communication Channels

The SRIO exposes several external and internal interfaces.

3.3.3.1 External Interfaces

- Ethernet interface for PROFINET and IoTCore communication
- Power supply connectors including daisy-chain functionality
- Rotary switches for addressing and special operating modes
- Safe digital input interfaces (F-DI)
- Safe digital output interfaces (F-DO)
- LED indicators for device status visualization

3.3.3.2 Internal Interfaces

- SysCom interface between COM and SCPU
- IPC interface between SCPU1 and SCPU2
- JTAG debugging interfaces for development and maintenance purposes

3.3.4 Communication Protocols

The following communication protocols are supported by the system:

- **PROFINET:** Industrial Ethernet protocol used for process communication between the SRIO and the F-Host
- **PROFIsafe:** Safety communication protocol operating on top of PROFINET according to the black-channel principle
- **HTTP/JSON:** Used by the IoTCore for diagnostics, monitoring, device information, and firmware update handling

The system supports HTTP communication only. HTTPS, MQTT, and WebSocket communication are not implemented.

3.3.5 System Classification

The SRIO is classified as a safety-related industrial automation component.

- IEC 61508 SIL 3
- EN ISO 13849-1 Performance Level e (PL e), Category 4

The device serves as a safety gateway between field devices and a safety PLC within a PROFINET/PROFIsafe environment.

3.3.6 Assets

Assets are resources that require protection against unauthorized modification, disclosure, or disruption.

3.3.6.1 Configuration Data

- IP address
- MAC address

- Hostname
- Network settings
- F-Address
- PROFIsafe parameters
- iPar parameters
- DCP configuration data

These parameters are stored in persistent memory such as EEPROM and NVMEM.

3.3.6.2 Firmware

The firmware asset consists of:

- COM firmware
- SCPU firmware
- Bootloader
- NetX90 firmware

Firmware updates are performed through the IoTCore update mechanism.

3.3.6.3 Safety Configuration

- F-Parameters
- iPar configuration
- Safety mappings

- Safe input parameters
- Safe output parameters

The integrity of these parameters directly affects the execution of safety functions.

3.3.6.4 Process Data

- Input process data
- Output process data
- F-DI states
- F-DO commands
- Qualifier information

3.3.6.5 Diagnostic and Service Data

- Error logs
- Error events
- Diagnostic data
- Device status information
- Uptime information

3.3.6.6 Device Identity Data

Via IoT-Core

- Serial number

- Production date
- Hardware version
- Software version
- Device tag

3.3.7 Attack Surface

The attack surface consists of all externally reachable interfaces and functions that may provide an entry point for an attacker. The following attack surfaces were identified:

- HTTP-based IoTCore web interface
- REST-API IoTCore services
- Firmware update mechanism
- Ethernet communication interfaces
- PROFINET communication services
- PROFINET DCP configuration services
- PROFIsafe communication services
- Rotary switch interface
- EEPROM and persistent configuration storage
- Debug and programming interfaces (JTAG)
- Power supply interface

Particular attention is given to the firmware update process, IoTCore services, network communication interfaces, and persistent configuration storage because they provide direct

access to critical assets.

3.4 Research of Test Methods

Spoofing → Authentizität → IEC 62443 FR1/FR2 → Authentication Testing Schutz vor unbefugtem Zugriff auf Sicherheitsfunktionen und Steuerungen (1.1.9, 1.2.1) Tampering → Integrität → IEC 62443 FR3 → Integrity Testing Software, Daten und Kommunikationspfade müssen gegen absichtliche oder unbeabsichtigte Veränderung geschützt werden (1.1.9) Repudiation → Nachvollziehbarkeit → IEC 62443 FR6 → Audit Logging Test Nachweis legitimer und illegitimer Eingriffe; Protokollierung von Änderungen (1.1.9) Information Disclosure → Vertraulichkeit → IEC 62443 FR4 → Encryption Testing Schutz sicherheitsrelevanter Daten vor unbefugtem Zugriff Denial of Service → Verfügbarkeit → IEC 62443 FR7 → Availability Testing Sicherheitsfunktionen müssen auch bei Störungen oder Angriffen wirksam bleiben (1.2.1) Elevation of Privilege → Autorisierung → IEC 62443 FR2 → Privilege Escalation Testing Nur autorisierte Personen/Systeme dürfen sicherheitsrelevante Funktionen ändern oder ausführen

Spoofing (Identitätsdiebstahl) → Authentizität (IEC 62443 FR1) → Authentication Testing

Tampering (Manipulation) → Integrität (IEC 62443 FR3 / MaschVO Anhang III) → Integrity Testing

Repudiation (Abstreitbarkeit) → Non-repudiation (IEC 62443 FR6) → Audit & Logging Testing

Information Disclosure (Offenlegung) → Vertraulichkeit (IEC 62443 FR4) → Confidentiality Testing

Denial of Service (Dienstblockade) → Verfügbarkeit (IEC 62443 FR7) → DoS/ Robustness Testing

Elevation of Privilege (Rechteauserweiterung) → Autorisierung (IEC 62443 FR2) → Authorization Testing

Replay Testing → Replay Threats

Secure Update Testing → Firmware

Input Validation Testing → Manipulated Configurations

Fuzz Testing → Protocol Interfaces

Communication Security Testing → PROFINET/PROFIsafe/IoT

Secure Storage Testing → EEPROM/Remanent Data

3.5 Analysis of the Gateway Security Context

3.6 Derivation of Security Requirements

Welche Funktionen müssen getestet werden? Testziele ableiten

Ableitung aus: Machinery Regulation IEC 62443 TARA

3.7 Development of the Functional Security Testing Methodology

Problem aktueller Methodiken: - klassischer Funktionale Ansatz (Black-Box-Ansatz): Prüft nur Soll-Verhalten, Keine Aussage über Angriffswiderstand → Für Nachweisführung regulatorischer Anforderungen allein nicht ausreichend - Security Verificaton nach IEC 62443: Abstrakt, liefert keine konkreten Testfälle → bietet aber Grundlage für die Ableitung systematischer Testfälle - Penetration Testing: Geringe Reproduzierbarkeit, Ergebnis abhängig vom Tester → Für die Maschinenverordnung liefern Penetration Tests starke Evidenz, ersetzen jedoch keine strukturierte Verifikationsmethodik. - Fuzz Testing: Erfordert spezialisiertes Testsetup, schwierige Ergebnisanalyse → geeignet für Prüfung robuster Kommunikation und Fehlerbehandlung nach IEC 62443 - Protocol Security Testing - OWASP IoT Security Testing Guide: nicht speziell für OT entwickelt - Risk-based Security Testing: Aufwendige Risikoanalyse notwendig

In the context of industrial gateways, which act as critical boundaries at the IT/OT interface, these devices are primarily evaluated under the stringent requirements for network components.

Funktionale Tests prüfen, ob das System tut, was es soll. Security Tests prüfen, ob das System auch das unterlässt, was es nicht tun darf.

Deswegen kombiniertes Testframework:

1. Risk Assessment / Threat Modelling 2. Ableitung von Security Requirements 3. Funktionale Security Tests 4. Protocol Security Tests 5. Fuzz Testing 6. Gezielte Penetration Tests 7. Compliance-Mapping auf EU-Maschinenverordnung und IEC 62443

Testframework 1. Requirement Analysis

2. Asset Identification

3. Threat Modeling (TARA + STRIDE)

4. Mapping to IEC 62443 Requirements

5. Definition of Security Test Objectives

6. Test Implementation

7. Result Evaluation

8. Compliance Evidence

3.8 Security Test Categories

3.9 Test Case Structure

Test Matrix Structure: Requirement -> Threat -> Risk -> Countermeasure -> Test Category -> Test Case -> Evidence

Requirement

Threat

Objective

Preconditions

Procedure

Expected Result

Evidence

3.10 Roles and Responsibilities in Verification

RACI Matrix

3.11 Evaluation Criteria

Pass

Fail

Partial

Not Applicable

4 Implementation, Results, and Evaluation

4.1 Test Environment

4.1.1 Test Object

4.1.2 Test Setup

4.1.3 Toolchain

4.2 Application of the Testing Methodology

4.2.1 Authentication Tests

4.2.2 Authorization Tests

4.2.3 Configuration Manipulation Tests

4.2.4 Firmware and Update Protection Tests

4.2.5 Logging and Traceability Tests

4.2.6 Communication Security Tests

4.3 Results

4.3.1 Test Results Overview

4.3.2 Evaluation of Mitigation Effectiveness

5 Summary and Outlook

5.1 Summary of Findings

5.2 Future Work

Bibliography

Printed Sources

- [1] H. Gsell and A. Rajchowski, in *Software-Technologien und IT-Systeme für die Wohnungs- und Immobilienwirtschaft: Künstliche Intelligenz, Digitale Plattformen, Property Technologies, IT-Ökosysteme*. Wiesbaden: Springer Fachmedien Wiesbaden, 2026, ISBN: 978-3-658-51129-6. [Online]. Available: https://doi.org/10.1007/978-3-658-51129-6_4 (cit. on p. 2).
- [5] P. K. Garimella, "It-ot integration challenges in utilities," in *2018 IEEE 3rd International Conference on Computing, Communication and Security (ICCCS)*, 2018, pp. 199–204. DOI: 10.1109/CCCS.2018.8586807 (cit. on pp. 3 sq.).
- [6] J. Hicking, M.-F. Stroh, and S. Kremer, in *Smart and Sustainable Collaborative Networks 4.0*, L. M. Camarinha-Matos, X. Boucher, and H. Afsarmanesh, Eds., Cham: Springer International Publishing, 2021 (cit. on pp. 3, 17).
- [8] S. Liebl, L. Lathrop, U. Raithel, A. Aßmuth, I. Ferguson, and M. Söllner, "Analyzing the attack surface and threats of industrial internet of things devices," 2024. arXiv: 2405.16318 [cs.CR]. [Online]. Available: <https://arxiv.org/abs/2405.16318> (cit. on pp. 5 sq., 14).
- [9] C. Poppe, "Neue eu-maschinenverordnung: Von der richtlinie zur verordnung," *CIT-plus*, vol. 28, no. 10, pp. 32–35, 2025. [Online]. Available: <https://onlinelibrary.wiley.com/doi/abs/10.1002/citp.202501012> (cit. on p. 6).
- [10] Europäisches Parlament and Rat der Europäischen Union, *Verordnung (eu) 2023/1230 des europäischen parlaments und des rates vom 14. juni 2023 über maschinen und zur aufhebung der richtlinie 2006/42/eg des europäischen parlaments und des rates sowie der richtlinie 73/361/ewg des rates*, 06/14/2023. Accessed: Jul. 8, 2026. [Online]. Available: <https://eur-lex.europa.eu/legal-content/DE/TXT/?uri=CELEX:32023R1230> (cit. on pp. 6 sq.).
- [12] *Sicherheit von maschinen - schutz vor korruption*, Deutsche und Englische Fassung prEN 50742:2025, Norm-Entwurf, CENELEC, 2025 (cit. on pp. 8 sq., 14).

- [13] *IEC 62443-3-3:2013, Industrielle Kommunikationsnetze - IT-Sicherheit für Netze und Systeme - Teil 3-3: Systemanforderungen zur IT-Sicherheit und Security-Level*, International Electrotechnical Commission, 2019 (cit. on pp. 9 sq., 13 sq.).
- [14] *DIN EN IEC 62443-4-1 (VDE 0802-4-1):2018-10: IT-Sicherheit für industrielle Automatisierungssysteme - Teil 4-1: Anforderungen an den Lebenszyklus für eine sichere Produktentwicklung*, Deutsches Institut für Normung e. V. / VDE, 10/2018 (cit. on pp. 10 sq.).
- [15] *IEC 62443-4-2:2019, IT-Sicherheit für industrielle Automatisierungssysteme - Teil 4-2: Technische Sicherheitsanforderungen an Komponenten industrieller Automatisierungssysteme (IACS)*, International Electrotechnical Commission, 2019 (cit. on p. 12).
- [17] D. Vasović, G. Janačković, Ž. Vranjanac, S. Stamenković, and B. Vasović, "Enhancing CIA triad—confidentiality, integrity and availability in educational information systems through next-generation ISO/IEC 27001:2022-aligned security model," *Applied Sciences*, vol. 16, no. 12, 2026. [Online]. Available: <https://www.mdpi.com/2076-3417/16/12/6260> (cit. on pp. 12 sq.).
- [18] A. Khanna, "Introduction to cybersecurity," in *Securing an Enterprise : Maximizing Digital Experiences through Enhanced Security Measures*. Berkeley, CA: Apress, 2024, pp. 3–18. [Online]. Available: https://doi.org/10.1007/979-8-8688-1029-9_1 (cit. on pp. 12 sq.).
- [19] R. do Carmo and A. Schlensog, "Threat analysis and risk assessment," in *Automotive Threat Analysis and Risk Assessment in Practice: A practical guide to TARA following the ISO/SAE 21434 standard for automotive embedded and IT/OT systems*. Berlin, Heidelberg: Springer Berlin Heidelberg, 2025, pp. 37–51. [Online]. Available: https://doi.org/10.1007/978-3-662-69614-9_4 (cit. on pp. 13, 15–20).
- [24] O. B. Tauqeer, S. Jan, A. O. Khadidos, A. O. Khadidos, F. Q. Khan, and S. Khattak, "Analysis of security testing techniques," *Intelligent Automation & Soft Computing*, vol. 29, no. 1, pp. 291–306, 2021. [Online]. Available: <https://pdfs.semanticscholar.org/2aa1/9e333637ff153803c4fbd42fdad937e895e.pdf> (cit. on pp. 20 sq., 23).
- [25] B. Potter and G. McGraw, "Software security testing," *IEEE Security & Privacy*, vol. 2, no. 5, pp. 81–85, 2004. DOI: 10.1109/MSP.2004.84 (cit. on p. 20).
- [26] J.-L. Richier, "Security testing techniques," Technical report, DIAMONDS Consortium, 2011. Deliverable ID, Tech. Rep., 2011 (cit. on pp. 20–23).
- [27] N. T. Cong, L. Toan, and T. Minh, "An overview of static and dynamic analysis in application security testing," *Journal of Military Science and Technology*, vol. 99, no. 99, pp. 1–11, 2024 (cit. on pp. 21 sq.).

- [29] K. Scarfone, M. Souppaya, A. Cody, and A. Orebaugh, "Technical guide to information security testing and assessment," National Institute of Standards and Technology, NIST Special Publication 800-115, 09/2008. Accessed: Jul. 21, 2026. [Online]. Available: <https://csrc.nist.gov/pubs/sp/800/115/final> (cit. on pp. 22 sq.).

Online Sources

- [2] "Gateway," Elektronik-Kompendium, Accessed: Jul. 16, 2026. [Online]. Available: <https://www.elektronik-kompendium.de/sites/net/0901111.htm> (cit. on p. 2).
- [3] "Layers of osi model," GeeksforGeeks, Accessed: Jul. 16, 2026. [Online]. Available: <https://www.geeksforgeeks.org/computer-networks/open-systems-interconnection-model-osi/> (cit. on p. 2).
- [4] J. Hohn. "Gateway: Definition + alles wissenswertes für 2026," Placetel, Accessed: Jul. 16, 2026. [Online]. Available: <https://www.placetel.de/ratgeber/gateway> (cit. on p. 2).
- [7] "Operational technology (ot): Definition, architektur & praxis," HWI IT, Accessed: Jul. 16, 2026. [Online]. Available: <https://hwi-it.de/blog/operational-technology-ot-grundlagen/> (cit. on pp. 3 sq.).
- [11] M. Carl. "Neue eu-maschinenverordnung gilt ab 2027: Übergang langfristig vorbereiten," IHK Lippe zu Detmold, Accessed: Jul. 14, 2026. [Online]. Available: <https://www.ihk.de/lippe-detmold/hauptnavigation/beraten-und-informieren/innovation-und-digitalisierung/aktuelles2/neue-eu-maschinenverordnung-5683128> (cit. on p. 7).
- [16] EICTA Content Team. "What are the three goals of cybersecurity? the cia triad explained (2026)," Accessed: Jul. 19, 2026. [Online]. Available: <https://www.eicta.itk.ac.in/knowledge-hub/cyber-security/three-goals-of-cybersecurity-cia-triad> (cit. on pp. 12 sq.).
- [20] A. Gomstyn and A. Jonker. "Was ist ein angriffsvektor?" IBM Think, Accessed: Jul. 19, 2026. [Online]. Available: <https://www.ibm.com/de-de/think/topics/attack-vector> (cit. on p. 15).
- [21] "Was ist tara (threat analysis and risk assessment)?" microTOOL GmbH, Accessed: Jul. 20, 2026. [Online]. Available: <https://www.microtool.de/wissen-online/tara/> (cit. on pp. 15 sq.).
- [22] "Microsoft threat modeling tool threats, Stride model," Microsoft Learn, Accessed: Jul. 20, 2026. [Online]. Available: <https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats> (cit. on pp. 16 sq.).

- [23] L. Conklin. "Threat modeling process (historical)," OWASP Foundation, Accessed: Jul. 20, 2026. [Online]. Available: https://owasp.org/www-community/Threat_Modeling_Process (cit. on pp. 16 sq., 19).
- [28] "Security testing - software testing," GeeksforGeeks, Accessed: Jul. 21, 2026. [Online]. Available: <https://www.geeksforgeeks.org/software-testing/security-testing/> (cit. on pp. 21 sq.).

List of Figures

List of Tables

2.1	Comparison of Core Characteristics and Requirements in IT and OT Environments [5, p. 1] [7]	4
2.2	Mapping of STRIDE Threat Categories to Violated Cybersecurity Properties [19, p. 144] [23]	17
2.3	Technical Mitigation Techniques Mapped to STRIDE Threat Categories [23]	19
2.4	Comparison of Static Analysis Detection Approaches [27, p. 3, 8]	22
3.1	Regulatory Cybersecurity Requirements for Industrial Gateways derived from Regulation (EU) 2023/1230	24
A.1	List of artificial intelligence based tools used	46

A Note on the Use of Artificial Intelligence

Within the scope of this thesis, tools based on Artificial Intelligence (AI) were used. Table A.1 provides an overview of the tools used and their respective purpose of application.

Table A.1: List of AI-based tools used

Tool	Description of Use
ChatGPT	• Basic research on established principles of optical sensing for distance measurement (see Section ...) • Search for manufacturers of LiDAR sensors (see Section ...) • ...
ChatPDF	• Research and summarization of scientific studies in the field of ... • ...
DeepL	• Translation of the paper by [...]
Tabnine AI coding assistant	• Active plugin in MS Visual Studio for programming the ... • ...
...	• ...